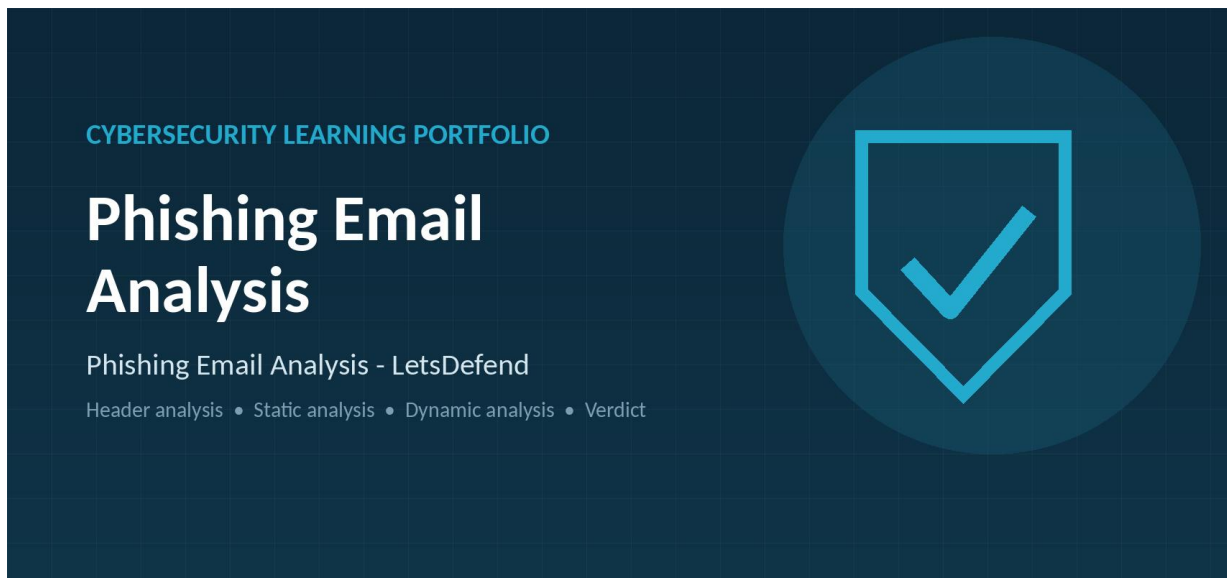




Phishing Email Analysis Course Learning Portfolio

A personal record of what I learned from the LetsDefend Phishing Email Analysis course, covering the introduction to phishing, information gathering, email headers and header analysis, static analysis, dynamic analysis, additional techniques, and the end-of-course quiz.

Prepared by	Mahnoor Mehtab Abbasi
Platform	LetsDefend
Course	Phishing Email Analysis (complete course portfolio)
Completion date	July 2026

Portfolio note

I wrote this portfolio after working through the course. The aim is not simply to repeat definitions, but to show that I understand how a reported email is examined from the header down to the attachment, and how an analyst reaches a defensible verdict.

Contents

1. Course profile
2. My understanding of phishing email analysis
3. Introduction to phishing
4. Information gathering
5. What is an email header and how to read it
6. Email header analysis
7. Static analysis
8. Dynamic analysis
9. Additional techniques
10. The phishing analysis workflow
11. Reaching a verdict and documenting the case
12. Indicators of compromise and safe handling
13. Common mistakes when analysing phishing emails
14. Tools used and referenced in the course
15. Course lesson questions and answers
16. Phishing quiz: questions, answers, and explanations
17. What I learned and the skills I developed
18. Personal reflection and real-world application
19. Glossary
20. Sources, next steps, and overall learning outcomes

1. Course Profile

Item	Details
Course / learning path	Phishing Email Analysis
Platform	LetsDefend
Lessons covered	Introduction to Phishing; Information Gathering; What is an Email Header and How to Read Them; Email Header Analysis; Static Analysis; Dynamic Analysis; Additional Techniques; Phishing Quiz
Topic area	Email security, phishing investigation, malware triage, and incident response
Learning method	Lesson reading, worked examples, simulated analysis, and end-of-course assessment

Why I took this course

Phishing is still the most common way an attacker gets a first foothold in an organisation, and in most SOCs a large share of the daily ticket queue is made up of user-reported emails. I wanted to move past the general advice of “don’t click suspicious links” and learn the actual method: what to collect, what each header field proves, how to inspect a link or an attachment without infecting myself, and how to write a verdict that another analyst can trust.

Before this course I judged emails mainly by how they looked. The course showed me that appearance is the weakest evidence available. A convincing message can be malicious and a badly written one can be harmless marketing. The decision has to come from the header chain, the authentication results, the reputation and behaviour of the links and files, and the context of the organisation.

What the course focuses on

The course follows the natural order of an investigation. It starts by explaining what phishing is and which forms it takes, then teaches how to collect the email safely and which fields to record. It then explains the structure of an email header and how to read the delivery path, followed by header analysis with SPF, DKIM, and DMARC. Static analysis covers links and attachments examined without execution, dynamic analysis covers detonation in a sandbox, and the final lesson adds the wider techniques an analyst uses to scope and contain a phishing campaign.

Learning goals in my own words

- Recognize the main phishing types and the objective behind each one.
- Collect a reported email safely and record the information needed to start an analysis.
- Read an email header and reconstruct the path the message actually travelled.
- Interpret SPF, DKIM, and DMARC results instead of trusting the displayed sender name.
- Examine URLs and attachments statically without executing anything.
- Use a sandbox to observe real behaviour and understand the limits of that evidence.
- Decide on a verdict, document the reasoning, and recommend containment actions.

2. My Understanding of Phishing Email Analysis

Phishing email analysis is the systematic examination of an email that is suspected to be fraudulent, in order to identify the threat it carries and to reduce the risk it creates. The work covers the content of the message, the details of the sender, and the technical markers that reveal deception. Analysts look for the familiar techniques used by attackers: spoofed or look-alike sender addresses, urgent or threatening language, and suspicious attachments or links. More advanced work involves reading metadata and, in mature environments, using detection models to spot patterns that a human reviewer would miss.

The purpose is not to label one message and move on. The purpose is to protect sensitive information by understanding the tactics the attacker used, so that email security controls and user awareness both improve as a result of the investigation.

What an analysis actually examines

Layer of the email	What I am looking for
Envelope and headers	The real sending server, the return path, the authentication results, and any mismatch with the displayed sender.
Sender identity	Look-alike domains, free mail providers used for business identities, newly registered domains, and display-name spoofing.
Content and language	Urgency, threats, financial requests, unusual instructions, secrecy, and requests to move to another channel.

Layer of the email	What I am looking for
Links	The true destination behind the anchor text, shortened or redirected URLs, credential-harvesting pages, and reputation history.
Attachments	File type against extension, hashes, embedded macros or scripts, archives, and password-protected containers.
Recipients and scope	Who else received the message, who interacted with it, and whether the campaign is wider than one mailbox.

My key takeaway

A phishing verdict is built from evidence at several layers. A single indicator such as a strange tone or a failed SPF check is a reason to look closer, not a conclusion on its own.

3. Introduction to Phishing

Phishing is a social-engineering attack delivered mainly by email, in which the attacker impersonates a person or organisation the recipient trusts in order to make them act. That action might be entering credentials on a fake login page, opening an attachment that installs malware, approving a payment, or replying with information the attacker can reuse. The attack targets the person rather than the technology, which is why it works even in well-defended networks.

The course places phishing in the Delivery phase of the Cyber Kill Chain, which is the model used to break an attack into stages. Delivery is the point at which the attacker transfers the prepared malicious content to the target system or person. Recognising this helps me see a phishing email as one step in a longer sequence rather than as an isolated event: reconnaissance came before it, and exploitation, installation, and command-and-control may follow if the delivery succeeds.

Why attackers rely on it

- It is cheap and scales easily; one campaign can reach thousands of mailboxes.
- It bypasses technical controls by convincing an authorised user to act on the attacker's behalf.
- Email is trusted by default in most workplaces and is used for genuine urgent requests.
- A single successful credential theft can be enough to enter the environment.

Main types of phishing

Type	How it works
Phishing	A broad campaign sent to many recipients using a generic pretext such as a delivery notice, invoice, or password expiry warning.
Spear phishing	A targeted message written for a specific person or team, using real names, projects, or suppliers to increase credibility.
Whaling	Spear phishing aimed at executives or other high-value individuals whose access or authority is worth the extra effort.
Business email compromise	The attacker impersonates or takes over a trusted internal or supplier account to request payments or sensitive data, often without any link or attachment.
Clone phishing	A legitimate message that the recipient has already seen is copied, with the link or attachment replaced by a malicious version.
Smishing and vishing	The same social engineering delivered by SMS or by voice call, frequently used to reinforce an email or to capture a one-time code.

What the attacker is usually trying to achieve

Objective	Typical delivery method
Credential theft	A link to a convincing copy of a login portal, often hosted on a newly registered or compromised domain.
Malware execution	An attachment such as a document with macros, a script inside an archive, an

Objective	Typical delivery method
	HTML file, or a disk image.
Financial fraud	A plain-text request to change bank details or approve an urgent transfer, usually with no malicious payload at all.
Information gathering	A harmless-looking reply request, a tracking pixel, or a survey used to confirm that the mailbox is active.
Session or token theft	A consent or device-authorisation prompt that grants the attacker access without ever capturing a password.

Common warning signs I now check for

- Pressure and urgency, such as an account that will be closed within hours.
- A mismatch between the display name and the actual email address.
- A domain that is almost, but not exactly, the organisation it claims to be.
- A request that bypasses the normal process, especially around payments or credentials.
- Generic greetings in a message that claims to be from a service that knows my name.
- Attachments or links that do not fit the stated purpose of the email.
- A reply-to address that is different from the sender address.

4. Information Gathering

Before any technical analysis begins, the email itself has to be obtained in a usable form and the basic facts recorded. This stage decides the quality of everything that follows. If the message is collected badly, the original headers are lost and the investigation is left with guesswork.

How the email should reach the analyst

A user who simply forwards a suspicious message replaces the original header chain with their own. The correct method is to forward the message as an attachment, or to export it as an .eml or .msg file, so the original envelope and headers survive. In many organisations the reporting button in the mail client does this automatically and sends the original to the security mailbox.

- Forward as attachment, or export the original .eml or .msg file.
- Do not open attachments or follow links on the workstation used for the investigation.
- Handle any sample in an isolated analysis environment, not on a production machine.
- Keep the original message intact so that later evidence requests can be answered.

Information I record at the start

Field	Why it matters
Sending address and display name	Establishes the claimed identity and allows a comparison with the real sending domain.
Sender server IP address	Identifies where the message actually came from and supports reputation and geolocation checks.
Return-Path and Reply-To	Shows where bounces and replies would go, which often exposes the attacker's real collection address.
Subject and date	Needed to search the mail gateway for the same campaign across other mailboxes.
Recipient and other recipients	Defines the initial scope and shows whether the message was targeted or broad.
Message-ID	A unique reference for the message that helps locate it in mail logs.
Attachments	File names, extensions, sizes, and hashes, recorded before anything is opened.
URLs	Full links in defanged form, including any redirect or shortener in the chain.
User interaction	Whether the recipient clicked, entered credentials, opened an attachment, or replied.

Question I always ask first

Did the user interact with the email? A message that was reported without interaction is a detection and prevention case. A message where credentials were entered is an incident, and password reset and session revocation cannot wait for the rest of the analysis.

Spoofing and why the sender address can lie

Email was not designed with an authentication mechanism, so an attacker can send a message in someone else's name. This technique is called spoofing, and it is the reason the visible sender cannot be trusted on its own. SPF, DKIM, and DMARC were introduced to make spoofing detectable, but their use is not mandatory and they can behave unexpectedly with forwarding and mailing lists, so the analyst still has to interpret the result.

To decide manually whether a message is spoofed, I first identify the sending SMTP address from the header, then obtain the SPF, DKIM, DMARC, and MX records of the claimed domain and compare them. Large organisations run their own mail infrastructure, so the WHOIS record of the sending IP address is another way of checking whether that server plausibly belongs to the organisation named in the message. Even when the address is not spoofed the email is not automatically safe, because a genuine corporate or personal mailbox may have been compromised and used by an attacker.

Email traffic analysis

Once the basic details are known, searching the mail gateway shows the true size of the attack and who it was aimed at. The course lists the parameters worth searching on, and each one catches a different variation of the same campaign.

Search parameter	What it catches
Sender address	Every message sent from exactly the same mailbox.
SMTP IP address	Messages sent from the same server even when the sender address changes.
Sender domain	The whole campaign when the attacker rotates the local part of the address.
Sender name or brand keyword	Attempts sent from several different providers using the same identity.
Subject	Related messages when both the sender address and the sending server keep changing.

The results should include the recipient addresses and the timestamps, not just a count. If the same users are repeatedly targeted, their addresses may have been leaked or published somewhere the attacker could collect them. Tools such as theHarvester gather addresses from public sources, which is why publishing individual work addresses on public pages creates an avoidable attack path.

5. What Is an Email Header and How to Read It

An email has two parts: the header and the body. The body is the message the user sees. The header is the technical record of how the message was created and delivered, written by the sending client and added to by every mail server along the way. Because most of it is generated by infrastructure rather than by the sender, it is far more reliable evidence than the visible content.

The fields I read most often

Header field	What it tells me
--------------	------------------

Header field	What it tells me
From	The identity shown to the recipient. It is written by the sender and can be forged, so it proves nothing on its own.
To / Cc / Bcc	The visible recipients. A message addressed to undisclosed recipients or to an unrelated address is a common bulk-phishing sign.
Subject	The pretext used, and a useful search term for finding the rest of the campaign.
Date	When the message was composed. Comparing it with the delivery timestamps can reveal manipulation or long delays.
Return-Path	The envelope sender used for bounces. A mismatch with the From address is a strong indicator of spoofing.
Reply-To	Where a reply will actually be sent. Attackers use this to redirect conversations to a mailbox they control.
Message-ID	A unique identifier for the message. Its format often reveals the true sending platform.
Received	The delivery chain. Each server adds one line, so the path can be reconstructed from these entries.
Authentication-Results	The receiving server's summary of the SPF, DKIM, and DMARC checks.
Content-Type and MIME parts	The structure of the message, including HTML content and attached files.
X- headers	Vendor-specific information added by gateways and filters, such as spam scores and policy decisions.

Reading the Received chain

The Received lines are written in reverse order. The line closest to the bottom of the header was added first, by the server that accepted the message from the sender, and the line at the top was added last, by the server that delivered it to the mailbox. Reading from the bottom upwards therefore reconstructs the journey in the order it happened.

1. Start at the lowest Received line and note the originating host name and IP address.
2. Follow each hop upward, recording the sending host, receiving host, protocol, and timestamp.
3. Check that the timestamps move forward consistently; a jump backwards or a large unexplained gap deserves attention.
4. Look for a hop that does not belong to the claimed sender's infrastructure.
5. Treat the earliest lines with care: an attacker can add fake Received entries before the message enters trusted infrastructure.

Important distinction

Only the Received lines added by servers I trust can be relied on. Everything written before the message reached that trusted boundary could have been fabricated by the sender.

6. Email Header Analysis

Header analysis turns the raw fields into a conclusion about whether the message really came from the organisation it claims to represent. The three mechanisms that make this possible are SPF, DKIM, and DMARC, and the receiving server usually summarises all three in the Authentication-Results header.

SPF, DKIM, and DMARC

Mechanism	What it checks	What a failure suggests
SPF	Whether the sending server's IP address is listed in the DNS record of the envelope sender's domain.	The message was sent from infrastructure the domain owner has not authorised, or it was forwarded through an intermediate service.
DKIM	Whether a cryptographic signature added by the sending domain still matches the message content.	The message was not signed by the claimed domain, or the content was altered after signing.
DMARC	Whether SPF or DKIM passed and aligned with the domain shown in the From header, and what policy the owner set.	The visible sender identity is not backed by either authentication method, which is the classic signature of direct domain spoofing.

Alignment is the point that took me longest to understand. SPF and DKIM can both pass for a domain the attacker owns while the From header still displays a completely different company. DMARC exists to close that gap by requiring the authenticated domain to match the one the recipient actually sees.

What a pass and a fail really mean

- A pass proves the message came from authorised infrastructure. It does not prove the message is safe: a compromised legitimate account passes every check.
- A fail is a strong indicator but not automatic proof of an attack. Mailing lists, forwarding rules, and misconfigured marketing platforms all produce genuine failures.
- A missing result usually means the check could not be performed, which is itself worth noting.
- The result is one input to the verdict, weighed alongside the content, links, and attachments.

My header analysis checklist

6. Compare the display name with the actual address in the From header.
7. Compare the From domain with the Return-Path and Reply-To domains.
8. Read the Authentication-Results line and record the SPF, DKIM, and DMARC outcomes.
9. Identify the originating IP address from the lowest trusted Received line.
10. Check the reputation, owner, and geolocation of that address and ask whether it fits the claimed sender.
11. Inspect the sending domain: registration age, registrar, and similarity to a legitimate brand.
12. Look at the Message-ID format and the X- headers for signs of a bulk-mailing platform.
13. Verify the timestamps across the delivery chain for consistency.
14. Record every finding in defanged form in the case notes.

Look-alike domains I learned to watch for

Technique	Example pattern
Character substitution	A visually similar letter or digit replaces the correct one, such as rn for m or 1 for l.
Extra or missing characters	A single added, removed, or transposed letter in an otherwise correct brand name.
Different top-level domain	The exact brand name registered under an unrelated or cheap extension.
Subdomain deception	The real brand appears as a subdomain of a domain the attacker controls.
Internationalised characters	Letters from another alphabet that render almost identically to the Latin ones.

7. Static Analysis

Static analysis means examining the message, its links, and its attachments without executing anything and without visiting the destination in a normal browser. It is the safest stage of the investigation and it often produces enough evidence to reach a verdict on its own.

Analysing the body and the links

- Read the raw HTML rather than the rendered message so that the true destination behind each anchor is visible.
- Compare the visible link text with the actual href value; a mismatch is a deliberate deception.
- Expand shorteners and redirect chains rather than following them in a browser.
- Check the registration age of the destination domain; a domain created days before the campaign is a serious warning.
- Look for credential-harvesting patterns such as a login form hosted on an unrelated domain or an address passed as a parameter in the URL.
- Note tracking pixels and remote images, which confirm to the sender that the mailbox is active.
- Submit URLs to reputation and scanning services, and review the resulting page rendering and requested resources.

Reputation checks and the trap of a cached result

Querying a web address on a multi-engine service shows whether antivirus engines already classify it as harmful. The detail that matters, and the one the course highlights, is that these services return a previous analysis rather than scanning again. If the attacker submitted the address themselves while it was still clean, the stored result will say harmless, and an analyst who does not look at the scan date will be misled by it. Checking when the last analysis ran, and requesting a fresh scan, is part of the check rather than an optional extra.

A previous scan can itself be informative. If an address linked to a phishing campaign was already submitted some time before the campaign began, that is consistent with an attacker testing the detection rate of their own infrastructure during preparation.

The same logic applies to the sending server. Looking up the SMTP IP address on a reputation service shows whether it is blacklisted or has been involved in malicious activity before. A blacklisted address often indicates that the message was sent from a compromised server rather than from infrastructure the attacker owns, which changes both the verdict wording and the blocking decision.

Analysing attachments

- Record the file name, size, and extension exactly as received.
- Calculate the MD5, SHA1, and SHA256 hashes before doing anything else, and use them for reputation lookups.
- Confirm the real file type from its signature rather than trusting the extension.
- Inspect documents for macros, embedded objects, and external template references.
- Extract readable strings and look for URLs, commands, encoded content, and script fragments.
- Treat archives and password-protected files as deliberate attempts to defeat scanning, and note the password if it was supplied in the message body.
- Never open the file with the application it was designed for on a normal workstation.

File types that deserve extra caution

Category	Why it is used by attackers
Office documents with macros	Macro code runs on open or on enable, and is often used only to download the real payload.
Scripts	Small script files execute directly on the operating system and are easy to obfuscate.
Archives	Compression hides the payload from simple scanning, and a password in the email body defeats gateway inspection.
HTML attachments	The file itself renders a local copy of a fake login page, so no suspicious domain appears in the link.
Disk images and containers	Mounting the file exposes an executable while avoiding some download protections.
Shortcut files	A shortcut can carry a full command line while displaying a harmless icon and name.

Safety rules I follow during static analysis

Work in an isolated environment; defang every URL and address before writing it into notes or tickets; never open an attachment or visit a link from a production machine; and remember that uploading a sample to a public service may expose confidential information contained in it.

8. Dynamic Analysis

Dynamic analysis means executing the sample in a controlled, isolated environment and recording what it actually does. It answers the questions static analysis cannot: what the file writes to disk, which processes it starts, what it changes on the system, and where it tries to connect.

What I observe during detonation

Observation area	What I am looking for
Process activity	The process tree, parent and child relationships, and the full command lines used, including any interpreter launched by a document.
File system activity	Files created, modified, or deleted, especially payloads dropped into temporary or user profile directories.
Registry and persistence	Run keys, scheduled tasks, services, or startup entries that would survive a reboot.
Network activity	DNS lookups, HTTP or HTTPS requests, downloaded payloads, and any command-and-control address contacted.
Credential and browser access	Attempts to read stored passwords, cookies, or session tokens.

Observation area	What I am looking for
Displayed content	For a URL, the rendered page, the login form presented, and where the submitted data would be sent.

Why the sandbox result is not the whole answer

- Malware can detect a virtual or analysis environment and stay inactive, producing a clean report for a dangerous file.
- Some payloads run only after a delay, a reboot, or a user action that the sandbox does not perform.
- Campaigns are often geofenced, so the destination behaves differently depending on where the request comes from.
- The attacker may have taken the payload offline by the time of analysis, leaving nothing to download.
- A password-protected archive will not detonate unless the password from the email body is supplied.
- A clean report is therefore evidence of nothing observed, not evidence of safety.

How I combine the two stages

Static analysis tells me what the sample is. Dynamic analysis tells me what it does. A confident verdict usually comes from agreement between the two, supported by the header evidence and the reputation of the indicators involved.

9. Additional Techniques

The final lesson covers the work that surrounds the technical analysis: establishing how far the campaign reached, containing it, and making sure the organisation is better protected afterwards. This is the part that turns an analysis into an outcome.

Scoping the campaign

- Search the mail gateway or mail logs for the sender address, sending domain, subject, and originating IP address.
- Search for the attachment hash and for the URL across all delivered mail, not only the reported mailbox.
- Check delivery status for each match: delivered, quarantined, or blocked.
- Use proxy and DNS logs to find out whether anyone actually reached the destination.
- Use endpoint telemetry to check whether the attachment was opened or the payload executed.
- Identify which accounts may have submitted credentials, and treat those as incidents rather than reports.

Containment and response actions

Action	When I would recommend it
Remove the message from all mailboxes	As soon as the message is confirmed malicious and other copies have been found.
Block the sender, domain, and originating IP	When the infrastructure is attacker-controlled rather than a compromised legitimate service.
Block the URL at the proxy or DNS layer	When the destination hosts a credential-harvesting page or delivers a payload.
Add file hashes to endpoint blocklists	When a malicious attachment has been confirmed by static or dynamic analysis.
Reset passwords and revoke sessions	Whenever a user has entered credentials, without waiting for the rest of the analysis.
Isolate an endpoint	When execution has been confirmed on the device, following the organisation's approval process.
Notify and educate the recipients	When a campaign has reached a wide audience or uses a pretext likely to succeed again.

Feeding the result back into detection

A closed phishing ticket should leave the organisation stronger. The indicators collected during the analysis become blocklist entries and detection content, the pretext becomes an awareness example, and repeated false positives from the reporting channel become feedback for the mail filtering team. If the same benign newsletter is reported and closed every week, the correct response is to tune the rule, not to keep closing the ticket.

10. The Phishing Analysis Workflow

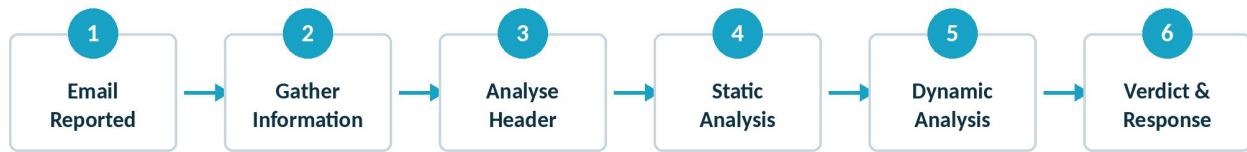


Figure 1: The phishing analysis lifecycle from a reported email to a documented verdict and response.

15. Receive the reported email as an attachment or exported file so the original headers are preserved.
16. Record the basic facts: sender, recipients, subject, date, message identifier, links, attachments, and any user interaction.
17. Analyse the header: authentication results, return path, reply-to, delivery chain, and originating address.
18. Perform static analysis on the body, the links, and the attachments without executing anything.
19. Detonate the sample or the URL in a sandbox when static analysis is inconclusive or when behaviour needs to be confirmed.
20. Scope the campaign across the mail platform, proxy logs, and endpoint data.
21. Decide the verdict and record the evidence that supports it.
22. Recommend or perform containment, then close or escalate the case with clear notes.

What good case notes should contain

- A one-line summary of the message and the reason it was reported.
- The sender identity as displayed and as authenticated.
- The authentication results and the originating infrastructure.
- Every indicator in defanged form, with the hashes of any attachment.
- The static and dynamic findings, and the tools used to obtain them.
- The scope: how many recipients, how many interactions, and which systems are affected.
- The final verdict with the specific evidence that supports it.
- The containment actions taken or recommended, and any escalation.

11. Reaching a Verdict and Documenting the Case

Verdict	What it means	Typical response
Malicious	The message carries a confirmed payload, credential-harvesting page, or fraudulent request.	Remove from mailboxes, block indicators, check for interaction, and escalate if execution occurred.
Suspicious	Indicators are concerning but the evidence is incomplete, for example an unreachable destination.	Quarantine, monitor, warn the recipients, and document what could not be confirmed.
Spam or unwanted	Bulk commercial mail with no malicious intent, even if the content is annoying or misleading.	Filter or tune the rule, close with an explanation, and no incident is raised.
Legitimate	The message is genuine and the report was a false positive from a cautious user.	Close with a clear reason, thank the reporter, and consider whether the filter caused confusion.

A false positive I can now explain

A marketing email sent through a bulk delivery platform often fails a naive check. The visible sender is the brand, the actual sending infrastructure belongs to the platform, and every link is rewritten as a tracking redirect. To a user, and to a rule that only compares domains, this looks exactly like spoofing with obfuscated links. The difference is visible in the authentication results, in the age and ownership of the sending infrastructure, and in the fact that the final destination after the redirect is the brand's own site. Recording that reasoning matters, because writing "false positive" with no explanation teaches nobody anything.

The standard I try to meet

Another analyst should be able to read my notes, follow the same evidence, and reach the same verdict without repeating the investigation.

12. Indicators of Compromise and Safe Handling

Every phishing analysis produces indicators that can be reused for blocking, hunting, and detection. Recording them in a consistent and safe format is part of the job.

Indicator type	Where it comes from	How it is used afterwards
Sender address and domain	The From, Return-Path, and Reply-To headers.	Mail gateway blocklists and searches for related messages.
Originating IP address	The trusted Received lines.	Reputation checks, mail filtering, and correlation with other campaigns.
URL and domain	The message body and any redirect chain.	Proxy and DNS blocking, and hunting through web traffic logs.

Indicator type	Where it comes from	How it is used afterwards
File hash	The attachment, calculated before analysis.	Endpoint blocklists, reputation lookups, and searches across other mailboxes.
Subject and pretext	The message itself.	Finding the rest of the campaign and building awareness material.

Defanging

Indicators are written in a modified form so that no tool, ticketing system, or reader can accidentally turn them into a working link. The convention is simple and should be applied everywhere an indicator is recorded.

Original form	Defanged form
http:// and https://	hxxp:// and hxxps://
A dot inside a domain or an address	The dot enclosed in square brackets
An @ symbol in an email address	The symbol enclosed in square brackets
Example malicious link	hxxps://secure-login[.]example-update[.]com/verify
Example sender address	billing[@]example-update[.]com

13. Common Mistakes When Analysing Phishing Emails

This is the section I expect to reread most often. Most weak phishing investigations fail on habit rather than on knowledge.

Weak habit	Better approach
Judging the email by how professional it looks	Base the verdict on headers, authentication results, link destinations, and file behaviour.
Trusting the From field	Confirm the sender through SPF, DKIM, DMARC alignment, Return-Path, and the originating server.
Opening the link or attachment to “just check”	Use static analysis first and a sandbox second, always in an isolated environment.
Treating a clean sandbox report as proof of safety	Consider evasion, delayed execution, geofencing, and offline payloads before clearing a sample.
Analysing only the reported mailbox	Search the whole mail platform for the same sender, subject, hash, and URL.
Ignoring whether the user interacted	Ask directly, and reset credentials immediately if any were submitted.
Pasting live links into tickets and chats	Defang every indicator before recording or sharing it.
Closing repeated reports without feedback	Report recurring false positives so the mail filtering rule can be tuned.
Writing a verdict with no evidence	Record the specific findings that support the conclusion and the tools used to obtain them.

A personal checklist before I close a phishing ticket

Have I read the original headers rather than a forwarded copy? Have I checked SPF, DKIM, and DMARC alignment? Have I resolved every link to its true destination? Have I hashed and checked every attachment? Do I know whether the user interacted? Have I searched for other recipients? Are all indicators defanged and recorded? Would another analyst reach my verdict from my notes alone?

14. Tools Used and Referenced in the Course

Tool or resource	What I use it for
Email header analysers	Parsing the Received chain and the authentication results into a readable delivery timeline.
WHOIS and domain age lookups	Checking when a sending or destination domain was registered and who owns it.
Reputation and multi-engine scanners	Checking hashes, URLs, domains, and IP addresses against known detections.

Tool or resource	What I use it for
URL inspection services	Rendering a destination page safely and reviewing the resources it requests.
Sandbox platforms	Detonating attachments and URLs to observe process, file, registry, and network behaviour.
Document and macro inspection utilities	Examining Office file structures and extracting embedded macro code without opening the document.
Metadata and strings utilities	Reading file metadata and extracting readable content such as URLs and commands.
Mail gateway and log search	Finding every copy of the campaign and confirming delivery status.

Note on tooling

The specific products change between organisations, and the LetsDefend environment provides its own email security, log management, endpoint, threat intelligence, and sandbox pages. What transfers between environments is the order of the questions, not the name of the tool.

15. Course Lesson Questions and Answers

Two lessons in this course include practical exercises with an email file to analyse. The questions are answered by reading the raw message rather than by recalling a definition, which is exactly the skill the course is teaching. Below I record each question, the answer, and the method I used to reach it.

Exercise-data note

The exercise files are provided inside the lesson and are protected with the password used for malware samples so that they cannot execute accidentally. The answers below match the published exercise data set and were cross-checked against community walk throughs. If LetsDefend updates the training data, I would verify the current value in my own dashboard before submitting it.

15.1 What Is an Email Header and How to Read Them?

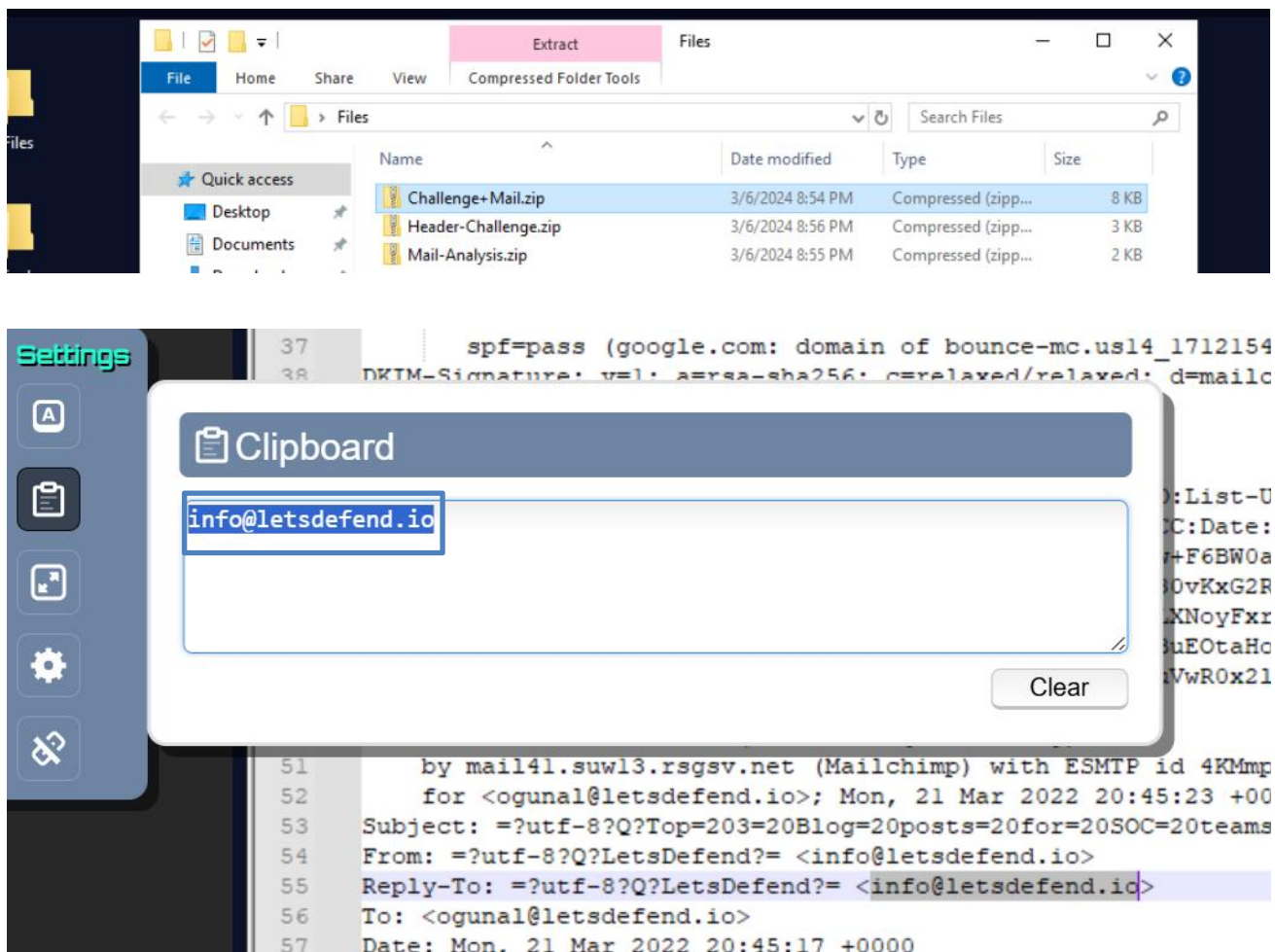
Exercise file: Challenge Mail.zip, provided on the lesson machine at C:\Users\LetsDefend\Desktop\Files. File password: infected.

Question 1

Question: If we wanted to respond to this email, what would be the recipient's address?

Answer: info@letsdefend.io

How I found it: The address a reply is sent to is held in the Reply-To header, not in the From header. I opened the extracted .eml file in a text editor and searched for the Reply-To field.



Question 2

Question: What year was the email sent?

Answer: 2022

How I found it: The Date header records when the message was composed. Reading the year from that field answers the question, and comparing it with the delivery timestamps is also a useful habit.

```
X-Received: by 2002:a25:1344:0:b0:633:7592:9c0f with SMTP id 65-20020a251344
Mon, 21 Mar 2022 13:45:24 -0700 (PDT)
ARC-Seal: i=1; a=rsa-sha256; t=1647895524; cv=none;
```

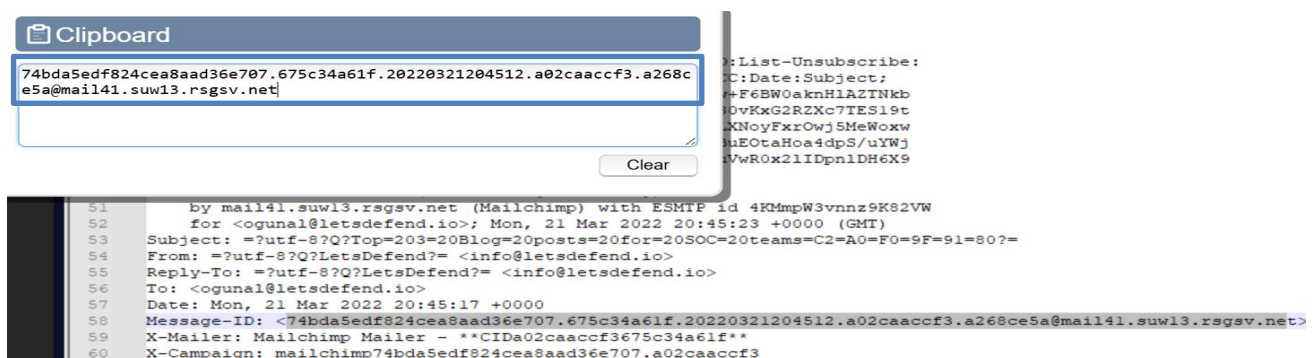
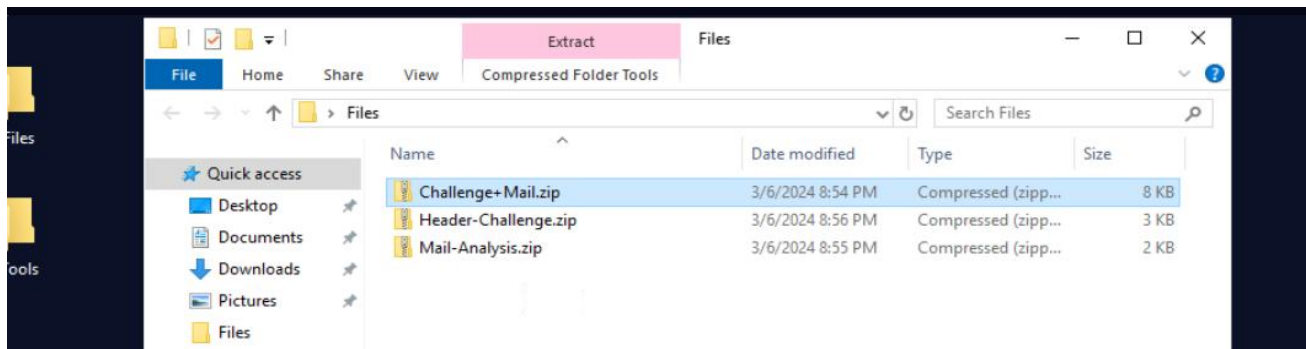
Question 3

Question: What is the Message-ID? (without the angle brackets)

Answer:

74bda5edf824cea8aad36e707.675c34a61f.20220321204512.a02caaccf3.a268ce5a@mail41.suw13.rsgsv.net

How I found it: The Message-ID header holds a unique identifier for the message. The angle brackets that enclose it in the raw header are part of the syntax and are removed before submitting the answer. The domain at the end of the value also reveals the sending platform that generated the message.



15.2 Email Header Analysis

Exercise file: Header-Challenge.zip, provided on the lesson machine. File password: infected.

Question 1

Question: Are the sender's address and the address in the Reply-To area different? (Answer format: Y/N)

Answer: Y

How I found it: I compared the From header with the Reply-To header. They point to different mailboxes, which means a reply would not go back to the party the message appears to come from. This mismatch is one of the clearest indicators of a phishing attempt.

```

10 20220222021744100.N118.7321.03E1@mx.google.com
Tue, 22 Feb 2022 11:17:44 +0900
Reply-To: <mrs.dara@daum.net>
From: "Mrs. Dara Patton"<mrs.dara@jcom.home.ne.jp>
To: me
Subject: Re: May God Bless You..

```

Question 2

Question: If I want to reply to this email, which address will it be sent to?

Answer: mrs.dara@daum.net

How I found it: The value comes from the Reply-To header. It uses a free mail provider that has no relationship to the identity claimed in the From field, which confirms that the attacker wants the conversation redirected to a mailbox they control.

```

10 20220222021744100.N118.7321.03E1@mx.google.com
Tue, 22 Feb 2022 11:17:44 +0900
Reply-To: <mrs.dara@daum.net>
From: "Mrs. Dara Patton"<mrs.dara@jcom.home.ne.jp>
To: me
Subject: Re: May God Bless You..

```

Question 3

Question: What IP address was the email sent from?

Answer: [222.227.81.181](https://www.iana.org/numbers/222.227.81.181)

How I found it: I read the Received chain from the bottom upwards and took the address of the server that first accepted the message.

```

Received: from mgw1.mx.zaq.ne.jp (snd01105-jc.im.kddi.ne.jp. [222.227.81.181])
by mx.google.com with ESMTPS id y4si10368943pfi.188.2022.02.21.18.17.45
(version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
Mon, 21 Feb 2022 18:18:08 -0800 (PST)

```

What these exercises are really testing

Both exercises could be answered by looking in the right header field, but the point is broader. They test whether I can open a raw message, navigate its structure, and separate the identity a message claims from the evidence the infrastructure recorded. The second exercise adds the reasoning step: a Reply-To that differs from the sender is not just a field to read, it is a finding that changes the verdict.

Lessons without a practical exercise

Introduction to Phishing, Information Gathering, Static Analysis, Dynamic Analysis, and Additional Techniques are reading lessons in the course structure I worked through, so they carry no separate answer field. I have recorded my understanding of each of them in sections 3, 4, 7, 8, and 9 of this portfolio, and the end-of-course quiz draws on all of them.

16. Phishing Quiz: Questions, Answers, and Explanations

The course finishes with a quiz that draws on every lesson rather than on a single dashboard. It is a multiple-choice assessment, so it tests whether the concepts from the reading lessons have actually connected, not whether I can locate a value in a header. Below I record each question with all of the options presented, the answer I selected, and my reasoning.

Quiz name	Phishing Quiz
State	Finished
Result	30 points (all six questions correct)

Question 1

Question: At what stage of the Cyber Kill Chain are phishing attacks carried out?

- Installation
- **Delivery**
- Command Control
- Actions on objective

Answer: Delivery

Explanation: Delivery is the stage at which the attacker transfers the prepared malicious content to the target system or person, and an email is exactly that transfer mechanism. Installation and command-and-control come later, and only if the delivery succeeds and the payload runs.

Question 2

Question: Where should you check to see if an email is spoofed?

- Email body
- Email signature
- **✓ Email header**
- Email sender name

Answer: Email header

Explanation: The body, the signature, and the displayed sender name are all written by whoever sent the message, so an attacker controls them completely. The header records what the mail infrastructure observed, including the authentication results and the delivery chain, which is why it is the only place spoofing can actually be detected.

Question 3

Question: Which protocol does not help you to determine whether an email has been spoofed or not?

- **✓ UDP**
- DKIM
- SPF
- DMARC

Answer: UDP

Explanation: SPF, DKIM, and DMARC are the three email authentication mechanisms built specifically to expose spoofing. UDP is a transport-layer protocol with no relationship to sender identity, so it contributes nothing to that decision.

Question 4

Question: What does SMTP stand for?

- Simple mail transfer problem
- Speed Mail Transfer Protocol
- Super Mail Transfer Protocol
- ✓ **Simple Mail Transfer Protocol**

Answer: Simple Mail Transfer Protocol

Explanation: SMTP is the protocol used to send mail between servers. It matters in this course because the SMTP address recorded in the header is the value I check for reputation, ownership, and geolocation, and the value I search across the mail gateway to size a campaign.

Question 5

Question: Which of these is not part of the header of an email?

- From
- To
- SPF
- ✓ **Check**

Answer: Check

Explanation: From and To are standard header fields, and the SPF result appears in the header as part of the authentication information added by the receiving server. There is no header field called Check, so that is the option that does not belong.

Question 6

Question: Which of the following cannot be achieved through a phishing attack?

- Sending a malicious URL
- Sending a malicious file
- ✓ **SQL injection**
- Social engineering attack

Answer: SQL injection

Explanation: Phishing delivers content to a person and relies on that person acting on it, which covers malicious URLs, malicious attachments, and social engineering in general. SQL injection is a technical attack against a database through an application input field, so it is not something an email itself carries out.

What the quiz tests as a whole

The six questions map onto the course in order: where phishing sits in the attack lifecycle, where the evidence of spoofing lives, which protocols produce that evidence, the protocol that carries the mail, the structure of the header itself, and the boundary of what a phishing email can and cannot do. Remembering an answer helps once; understanding why it is correct is what makes the knowledge usable when a real reported email arrives.

17. What I Learned and the Skills I Developed

Knowledge I gained

I can now explain what phishing is in its different forms, what an attacker is trying to achieve in each case, and how an email is examined from the header chain down to the behaviour of an attachment. I understand that the visible sender is a claim rather than a fact, that authentication results are evidence rather than a verdict, and that scoping and containment matter as much as the technical analysis.

Practical skills

- Collecting a reported email in a form that preserves the original headers.
- Reading a header and reconstructing the true delivery path from the Received chain.
- Interpreting SPF, DKIM, and DMARC results, including alignment.
- Identifying look-alike domains and display-name spoofing.
- Extracting and deranging links, and resolving redirect chains safely.
- Hashing and inspecting attachments before any execution.
- Reading a sandbox report and recognizing its limits.
- Scoping a campaign across mail, proxy, and endpoint data.
- Writing a defensible verdict with the evidence that supports it.

Skills matrix

Skill area	Evidence from this course	Current level
Phishing fundamentals	I can describe the main phishing types and the attacker objective behind each.	Foundational
Header analysis	I can read a Received chain and interpret authentication results.	Foundational
Static analysis	I can examine links and attachments without executing them.	Foundational
Dynamic analysis	I can read sandbox behaviour and explain why a clean report is not proof.	Developing
Scoping and containment	I can list the searches and actions that follow a malicious verdict.	Developing
Documentation	I know what a phishing case note must contain to be reviewable.	Developing
Detection feedback	I can explain how repeated false positives should be reported and tuned.	Foundational

18. Personal Reflection and Real-World Application

Personal reflection

The most useful change this course produced in me was moving the decision away from appearance and towards evidence. I used to assume that a well-written email from a familiar brand was probably genuine and that a clumsy one was probably an attack. Both assumptions are unreliable. The header tells me where the message really came from, the authentication results tell me whether the sender identity is backed by anything, and the links and attachments tell me what the message was built to do.

The second lesson was about restraint. The instinct when a suspicious link appears is to open it and see what happens. The course made it clear why that instinct is dangerous and gave me a safer sequence to follow instead: read the raw source, resolve the destination, check reputation, and only then detonate in an environment built for it.

The third was that analysis without scoping is incomplete. One reported email usually represents a campaign. Until I have searched the mail platform for other copies and checked whether anyone interacted, I have examined a sample rather than handled an incident.

How I could use this knowledge at work

- Triage user-reported emails in a security mailbox during an entry-level SOC shift.
- Read headers and authentication results to separate spoofing from legitimate third-party senders.
- Analyse links and attachments safely and record the indicators for blocking.
- Search the mail platform to establish the true scope of a campaign.
- Recommend containment actions such as message removal, blocking, and credential resets.
- Feed recurring false positives back to the mail filtering team so rules improve.
- Turn a real campaign into a clear awareness example for the users who received it.

What I still need to practise

I want hands-on repetition with real samples: reading raw headers without a parser, extracting macros from documents, following multi-stage redirect chains, and interpreting full sandbox reports rather than summaries. My next goal is to complete end-to-end phishing investigation exercises where I collect the evidence myself, reach a verdict, and defend it in written case notes.

19. Glossary

Term	Meaning
Phishing	A social-engineering attack, usually delivered by email, that impersonates a trusted party to make the recipient act.
Spear phishing	A phishing message targeted at a specific person or team using details that make it credible.
Business email compromise	Fraud carried out through an impersonated or compromised business mailbox, often with no malicious payload.
Email header	The technical section of a message that records how it was created and delivered.
Received header	A line added by each mail server that handles the message, forming the delivery chain.
Return-Path	The envelope sender address used for delivery failures.
Reply-To	The address to which a reply is sent, which may differ from the visible sender.
SPF	A check of whether the sending server is authorised to send mail for the sender's domain.
DKIM	A cryptographic signature that shows a message was sent by the domain and not altered afterwards.
DMARC	A policy that requires SPF or DKIM to align with the visible From domain and defines the action on failure.
Static analysis	Examination of a message, link, or file without executing it.
Dynamic analysis	Observation of a sample's behaviour while it runs in an isolated environment.
Sandbox	A controlled environment used to detonate files or URLs safely and record what they do.
Indicator of compromise	An observable value such as a hash, URL, domain, or address that can be used for blocking and hunting.
Defanging	Rewriting an indicator so that it cannot be clicked or resolved by accident.
Credential harvesting	The use of a fake login page to capture usernames and passwords.
Look-alike domain	A domain registered to closely resemble a legitimate one in order to deceive readers.
Containment	The actions taken to stop a confirmed threat from spreading or continuing.

20. Sources, Next Steps, and Overall Learning Outcomes

What I can now explain

- What phishing is, which forms it takes, and what the attacker is trying to achieve.
- How a reported email should be collected so that the evidence survives.
- What each header field records and how to reconstruct the delivery path.
- How SPF, DKIM, and DMARC work, what alignment means, and what a pass or fail actually proves.
- How to analyse links and attachments statically without executing anything.
- What a sandbox observes, and why a clean report is not a clean verdict.
- How to scope a campaign and which containment actions match which findings.
- How to document a verdict so that another analyst can review and trust it.

Recommended next steps

- Complete full phishing investigation scenarios from report to closure.
- Practise reading raw headers manually before relying on a parser.
- Learn document and macro analysis in more depth in a controlled lab.
- Practise multi-stage URL analysis, including redirects and geofenced destinations.
- Map observed phishing techniques to the relevant MITRE ATT&CK initial-access techniques.
- Study mail gateway searching and message removal in a real administration console.

Source and accuracy note

The live LetsDefend lesson pages require an authenticated account. This portfolio was written from the course structure and lesson material supplied for this project, rewritten into a personal learning record rather than copied as course text. The lesson exercise answers in section 15 were cross-checked against published community walkthroughs of the same course, and the quiz in section 16 is recorded from my own completed attempt. Because course wording and any values drawn from the training dataset can change, I would verify every dynamic value in my own logged-in dashboard before final submission.

Course page: <https://app.letsdefend.io/training/lessons/phishing-email-analysis>

Course FAQ: <https://forum.letsdefend.io/t/faq-phishing-email-analysis/156>

Email header lesson FAQ: <https://forum.letsdefend.io/t/faq-what-is-an-email-header-and-how-to-read-them/28>

Header analysis lesson FAQ: <https://forum.letsdefend.io/t/faq-email-header-analysis/29>

Related course completed earlier: SOC Fundamentals (separate portfolio)

Final reflection

This course taught me that phishing analysis is a discipline rather than a judgement call. The email arrives claiming to be something; my job is to test that claim layer by layer, to prove what the message was built to do, to find out how far it reached, and to write down the reasoning clearly enough that the next person does not have to start again.